

Corporate Information Security Policy

Mandatory standards for authentication, credentials, data security, and incident response

1. Multi-Factor Authentication (MFA) Standards

MFA is strictly mandatory for all employees and contractors accessing any Acme system, application, or network resource. SMS-based text message verification and unencrypted email codes are prohibited due to SIM-swapping and interception risks. Only app-based authenticator push notifications (Okta Verify, Google Authenticator) and FIDO2/WebAuthn hardware security keys (YubiKey) are authorized authentication methods.

2. Password Security Policy

Corporate accounts must maintain high password entropy and adhere to the following standards:

- Passwords must be at least **14 characters in length** and include uppercase, lowercase, numeric, and special characters.
- Passwords expire automatically every **90 days**. Reusing any of the last 6 previous passwords is prohibited.
- Writing down passwords, sharing credentials with colleagues, or saving passwords in unencrypted files or web browsers is a critical security violation.
- All employees must utilize the company-issued **1Password** enterprise password vault for storing unique credentials.

3. Phishing Awareness & Mandatory Security Training

Cyber threats and email phishing are the primary vectors for corporate attacks. All employees must comply with the following training and reporting rules:

- **Mandatory Training:** All new hires must complete the 30-minute **Security Awareness Training** course within their first 14 days of employment.
- **Phishing Simulations:** The Security team conducts periodic, unannounced simulated phishing tests. Employees who fail simulations are required to take remedial refresher training.
- **Reporting Suspicious Emails:** Never click links or download attachments in unexpected emails. Report suspicious messages immediately using the 'Report Phishing' button in Outlook / Gmail or forward to phishing@company.com.

4. Device Security & Workstation Hygiene

Employees are responsible for securing company-issued laptops, phones, and devices at all times:

- **Automatic Screen Lock:** Workstations must automatically lock after **5 minutes of inactivity**. Lock your screen manually (Cmd+Ctrl+Q on macOS, Win+L on Windows) whenever leaving your desk.
- **Removable Media Ban:** Connecting personal USB flash drives, external hard drives, or unauthorized peripheral storage devices to company laptops is blocked and strictly prohibited.
- **Public Wi-Fi:** When working from coffee shops, airports, or public venues, connecting via corporate VPN is mandatory before transmitting any work data.
- **Clean Desk Policy:** Sensitive documents containing employee or customer data must be shredded or stored in locked cabinets when unattended.

5. Reporting Security Incidents & Lost Devices

Any suspected security breach, unauthorized access, malware detection, lost laptop, or compromised credential must be reported immediately (within 1 hour of discovery). Prompt reporting allows the Security Operations Center (SOC) to isolate compromised assets and prevent data exfiltration.

- **Security Incident Email:** security@company.com
- **24/7 Urgent SOC Hotline:** 1-800-555-0199 (Ext 4)
- **Slack Security Channel:** #security-incidents

Security Rule #1: Acme IT or Security personnel will NEVER ask you for your password or MFA verification code under any circumstances.